

TianShanOS

Complete Guide to the Security Page

Set up, check, and maintain your device's security settings

Version covered: TianShanOS 0.6.1

This guide describes the features and interface in TianShanOS 0.6.1. It may remain useful for later versions where those features are unchanged. A different version number does not automatically make the guide obsolete. If the interface, steps, or result messages differ, check the release notes for your installed version before proceeding.

Revised: October 9, 2026

Contents

1. Before you begin	3
2. Change device passwords	4
3. Connect to a server with an SSH key	5
4. Manage keys, hosts, and fingerprints	8
5. Configure HTTPS certificates and mTLS	10
6. Understand Config Pack limitations	12
7. Troubleshooting and incident response	14
8. Version notes and glossary	15

Use this guide to change device passwords, set up SSH access, check server identities, and manage certificates. For first-time setup, start with Chapters 1, 2, and 3. Certificate and Config Pack procedures are intended for administrators responsible for those features.

Use a trusted management network. The full web interface currently uses HTTP, and most API operations lack centralized login and permission enforcement. Keep the device on a controlled management network. Installing an HTTPS certificate does not switch the full web interface to HTTPS.

1. Before you begin

1.1 Find the task you need

Task	Where to go
Change the device's root or admin password	Account Security; Chapter 2
Connect to a server using an SSH key	Key Management and Deployed Hosts; Chapter 3
Copy keys or check a server's identity	Key Management and Known Host Fingerprints; Chapter 4
Set up certificates and mutual authentication	HTTPS Certificate; Chapter 5
Exchange encrypted configuration packages	Config Pack; Chapter 6. General configuration application is still unfinished

1.2 Accounts and device identity

- **admin** can open Security and see keys, hosts, certificates, and Config Pack controls, but not Account Security.
- **root** can also set the root and admin passwords or reset admin to its default password. These password-management operations check root authorization.
- A **Developer device** is identified by the organizational unit (OU) in its device certificate. This is a device identity. Only these devices can currently export Config Packs and SSH host configurations; signing in as root does not change it.

A visible button does not establish that its API enforces access permissions. Apart from operations such as password management that check authorization themselves, access must currently be limited through a trusted management network.

1.3 Prepare for the operation

1. Check that the browser's IP address belongs to the intended device and that your computer is on a trusted management network.
2. Confirm the SSH address, port, and username with the server administrator.
3. Deploying or revoking a public key through the page requires the remote account's password and password authentication. The server administrator decides whether to leave password authentication enabled afterward.
4. Before revoking access, deleting keys, or replacing certificates, make sure another management connection works: a server console, another administrator key, or the device's HTTP interface.

2. Change device passwords

These controls change TianShanOS login passwords. They do not change the SSH password on a remote server.

2.1 The prompt after first sign-in

If an account is still marked as having an unchanged password, a password-change prompt appears after sign-in. Set a long, unique password. Choosing to change it later dismisses the prompt without changing the password.

The prompt is not an account-settings screen that you can reopen at any time. If admin has already changed its password and needs another change, root can set it from Security.

2.2 Set a password as root

1. Sign in as root and open Security in the navigation bar.
2. Find the root or admin password controls under Account Security. Fill in the new password and its confirmation.
3. Select Set root password or Set admin password. The interface accepts 4-64 characters; four characters is a technical minimum. Use a long, unique password.

Check the result: sign in with the new password in a private browsing window before signing out of the original session. Setting a new password does not automatically end existing sessions.

If sign-in fails: check the account and device address first. Five consecutive failed attempts trigger a lockout of about five minutes. Avoid repeated guesses.

2.3 Reset the admin password

Root can select Reset admin to default to restore the password to `rm01` and clear the login lockout. Sign in as admin in a new session and set a unique password immediately afterward.

Use the default password only to recover access temporarily. Change it promptly and sign out of any sessions you no longer need.

3. Connect to a server with an SSH key

For initial setup, create an RSA key, deploy its public key, review the result, and test the connection. Check the server fingerprint as part of this process. When retiring a key, revoke access on every server first, confirm that the old key no longer works, and only then delete it from the device.

3.1 Create a key

1. In Key Management, select Generate New Key.
2. Choose an unused key ID, such as `backup01`. Use a short combination of English letters and numbers, no more than 10 characters, with no commas. The actual limit is 10 UTF-8 bytes; non-ASCII characters can use more than one byte each.
3. Choose RSA 2048 or RSA 4096. RSA 2048 is the default. ECDSA options are shown, but the current SSH workflow does not support them; choose RSA for SSH.
4. Add a comment or alias if useful. Turn on Exportable only if you need to back up or migrate the private key. There is no page control for changing this option later.
5. Set Hidden if needed, then select Generate. This option affects list display; it does not keep the actual key ID secret.

Check the result: after completion, the window closes and the list refreshes. Find the intended ID and RSA type, then open Public Key. Check that the complete text starts with `ssh-rsa`.

While you wait: do not submit again. Closing the window does not cancel generation on the device.

Message or situation	What to do
The ID is already in use	Choose another ID. The new-key workflow now rejects existing IDs rather than overwriting their keys
The key count limit has been reached	The SSH key store holds eight keys. Retire an unused key through the revocation process first
Storage or memory is insufficient	Resolve the device resource issue before trying again. Do not treat the failure as successful creation
The key was generated, but the list could not be refreshed	Refresh manually and check the key; do not generate it again
Generation has not been confirmed	The device may still be working. Wait and check the record; do not resubmit the same ID

Message or situation	What to do
Cleanup did not complete	Check device storage, involve an administrator if needed, and pause further key creation

Finding a record with the same ID proves only that a record exists. If the result is unconfirmed, check that it is the intended key before treating the operation as complete.

3.2 Deploy the public key

Deployment appends the public key to the remote account's `~/.ssh/authorized_keys`, allowing that account to accept the matching private key. It does not change the server password.

1. Select Deploy on the intended key's row.
2. Enter the server address, username, SSH port, and SSH login password.
3. Review the address and account, then select Start Deploy.
4. Read the result and check the corresponding record under Deployed Hosts.

The new version checks the host fingerprint before password authentication and rejects a changed fingerprint for a known host. However, first-time public-key deployment still automatically saves and trusts an unknown host's fingerprint without asking you to check it first. Use a controlled network for initial deployment and verify the full fingerprint through a trusted channel.

3.3 Understand the deployment result

What the result tells you	What to do next
The key was deployed, the host registered, and public-key sign-in verified	Check the host details, then test the actual task you need to run
The key was deployed and the host registered, but sign-in is unconfirmed	Select Test. If it fails, check remote authorization and account settings through another management connection
The key was deployed, but registration failed or is unconfirmed	Check the local list and remote authorization before deploying again
Deployment completed, but the list could not be refreshed	Refresh manually. A failed list refresh does not mean the remote key was not installed

Do not repeatedly deploy because the result is incomplete. Each deployment appends the key and may create duplicate entries. Use another management connection to inspect `authorized_keys` when you need to confirm the remote result.

3.4 Test the connection

1. Under Deployed Hosts, check the address, port, username, and key ID, then select Test.
2. If a Host fingerprint confirmation appears, obtain and compare a trusted fingerprint as described in Section 4.3 before choosing Trust & connect.
3. After connecting, the device attempts the fixed echo command `echo "TianshanOS SSH Test OK"`.

What success means: the test page still checks whether the request succeeded, not the remote command's exit status or output. Use it as a basic connection check. For an important task, verify the actual output, exit status, and permissions. This test also does not establish that sudo or other application commands will work.

If it fails: check connectivity, the SSH service, the account, and remote public-key authorization. Stop retrying if the fingerprint changes or the server's identity is uncertain.

3.5 Revoke access before deleting the local key

1. Confirm that another server-management connection works and that the original key remains on the device.
2. Select Revoke on the host row, enter the server password, and confirm Revoke & Remove. You can also start from the key row and enter the target details.
3. Read the result, then use a trusted connection to check that the public key and any duplicates are gone from `authorized_keys`. Confirm that the old key no longer works.
4. Revocation leaves an `authorized_keys.bak` backup. Handle it under the server's backup policy so old authorization is not restored later.
5. Check that the local host record was removed. The page now checks this request. If remote revocation succeeded but local removal failed, refresh and handle the local cleanup separately.
6. Only after every target server has been handled should you delete the old key and unneeded private-key copies.

If no matching public key is found: confirm that the account is correct and the key is absent on the server before choosing to remove only the local record.

If the host cannot be removed: a service may be using or protecting the record. Check service status and references under SSH Commands or the relevant automation settings. Finish stopping the service or resolving its references before trying again. Ask an administrator to check an uncertain state.

If revocation reports failure: identify which step failed. The remote key may already be gone even though local cleanup failed. Use the server's authorization and an actual sign-in check to establish the remote result. Keep the local key until this is resolved.

4. Manage keys, hosts, and fingerprints

4.1 Copy a public key or export a private key

Public key: select Public Key and copy the complete, single-line value for the server administrator. This is public material; sending it to the wrong person does not expose the private key. Access is granted when an administrator adds it to an account's authorization list.

Private key: export is available only if Exportable was enabled during creation. Select Private Key on a trusted computer and isolated management network. Store it in an approved secret store and clear temporary clipboard and download copies. Never paste it into chat, tickets, or logs.

If Copy does nothing: browsers may restrict clipboard access on an HTTP page. Select and copy the text manually, then check its boundary markers and completeness. Do not weaken browser security settings to enable copying.

4.2 Revoke, Remove, and Delete

Action	Effect
Revoke a public key	Attempts to remove server authorization; requires the remote password
Remove a host	Deletes a local connection record without revoking server access
Delete a key	Deletes local key material without contacting the server or revoking access
Remove a host fingerprint	Deletes a saved server-identity record, not its connection record or remote authorization

Deployed Hosts is a local list, not a live view of server authorization. An empty list does not prove that access has been removed, and a listed host is not guaranteed to be reachable.

4.3 Check the SSH server fingerprint

A fingerprint identifies the server you are connecting to. This page stores a SHA-256 digest as 64 hexadecimal characters. OpenSSH tools commonly display `SHA256:base64`. Ask the administrator for the same format before comparing; the strings cannot be compared directly.

After initial deployment: select View under Known Host Fingerprints and compare the full value with one obtained from a server console, asset inventory, or another trusted channel. The table shows only the first 32 characters, which is not enough for a complete check.

When Test asks for confirmation: the dialog shows the current full fingerprint. Verify it independently before selecting Trust & connect. If it has changed, also check the server identity, IP, port, and maintenance record. Do not approve simply because the dialog appeared.

If the fingerprint differs or its source is unclear: cancel the connection and investigate. If you previously used a password over an untrusted connection, treat it as potentially exposed. Change it through a trusted connection, review sign-in logs, and remove unwanted authorization. Do not send a password through the suspicious connection to revoke access.

After an authorized rebuild or host-key change: check the new full fingerprint and maintenance record first. Once verified, accept it in the Test confirmation dialog. Alternatively, remove the old entry, test again, and confirm the verified fingerprint. The Test path now requires explicit confirmation; do not assume reconnecting will automatically trust the new key.

Protect the SD card: known-host fingerprints are synchronized to plaintext JSON on the card. At startup, available SD fingerprint configurations replace the corresponding local records. These files are not signed; do not allow untrusted changes to them.

4.4 Import and export SSH host configurations

This dedicated `.tscfg` workflow stores the address, port, username, authentication type, and key ID. It contains no SSH password or private key and does not grant remote access. It is separate from the unfinished general application in Chapter 6.

To export: on a Developer device, select Export on the host row. For another device, supply and verify its certificate, generate the package, and select Download. Check that the file was saved. An ordinary device may show the control, but its export request is rejected.

To import:

1. Confirm that the package was made for this device, the SD card is writable, and the source has been verified through a trusted channel.
2. Make sure this device has the correct referenced key. A matching ID alone is insufficient; the key material must match the server's authorization.
3. Select Import Host, choose the file, and review the preview. Enable overwrite only when you intend to replace a configuration with the same name.
4. Confirm and restart as prompted. Import first saves the package to the SD card; loading and decryption are attempted at restart.
5. Allow startup loading to finish, refresh the host list, check the address, account, port, and key, then test.

A successful preview establishes neither signer trust nor that this device is the recipient. The recipient fingerprint is checked during loading. Startup now merges host configurations and keeps unrelated local records; importing one package does not clear the entire previous list.

Remove an incorrect record and check that its corresponding SD configuration has been cleared. A remaining package can load again after restart. Resolve service references if the record is in use. Also read Section 5.6 before replacing the device certificate.

5. Configure HTTPS certificates and mTLS

The current service on port 443 provides health, identity, and permission-test endpoints, not the full web interface. Default startup requires a device key, device certificate, client CA chain, and a valid device clock.

5.1 Know which certificate does what

- The **device certificate and private key** let the device prove its identity to clients.
- A **client certificate and private key**, held by a computer or service, let the client prove its identity to the device.
- The **client verification CA on the device** validates client certificates. It does not automatically make a computer or browser trust the device certificate.

This two-way authentication is called mutual TLS, or mTLS. Clients must still trust the device certificate's issuing CA and check its access name, permitted uses, and validity.

5.2 Read the status and set the device time

Saved, Within validity period, and HTTPS: Running describe storage, time validity, and service operation separately. One does not establish the others.

Status or situation	What to do
The device certificate, private key, or client verification CA is missing	Install the missing credentials using the following sections
Awaiting device time	Check that your computer's clock is correct, then select Set device time from this computer (browser source)
Not yet valid or Expired	Check the device clock and certificate dates; arrange renewal if it has expired
Within validity period, but HTTPS is not running	Read the displayed missing-credential, key-mismatch, or startup error; resolve it and refresh
The running service still uses previous credentials	Save other work and restart the device. Confirm the new credentials meet startup requirements and are in use
Storage or status is unconfirmed	Refresh and check. Restart if instructed; avoid repeated installation or deletion

After setting the time, check the displayed device time and synchronization status. When the service is not running, the system attempts startup once credential and time requirements are met. If it stays stopped, investigate the displayed reason rather than treating installation as proof that it is ready.

5.3 Generate a device key and certificate request

1. Select Generate Key Pair. This creates a separate ECDSA P-256 private key, unrelated to SSH keys. It cannot be exported through this interface.
2. If a key already exists, read Section 5.6 first. Proceeding overwrites it.
3. Select Generate CSR. Enter the device ID (CN), Organization, and Department, or leave all fields blank. Department corresponds to the certificate's organizational unit (OU).
4. Select Generate Certificate Signing Request and send the complete CSR text to your CA administrator.

Use a short, stable device ID. English letters and numbers are easiest to keep within the 63-byte UTF-8 limit. Non-ASCII characters can use multiple bytes. Shorten fields if the interface reports a length error.

Check names before issuance: the custom-field path does not generate a SAN. With all fields blank, CN is fixed at `TIANSHAN-DEVICE-001`; the current IP is added as an IP SAN only if available. No DNS SAN is added. Have the CA administrator use a controlled issuance process to include the actual IP or DNS names and required authentication purposes in the final certificate. This form cannot edit SANs.

A CSR contains no private key and does not install a certificate. Have the CA administrator inspect its public key, subject, and SAN before issuance.

5.4 Install the device certificate

1. Obtain a PEM certificate that matches the current device private key.
2. Select Install Cert, paste the complete text including its boundary markers, and select Install.
3. Check the saved result, certificate validity, and actual HTTPS status. Review the subject, issuer, and dates.

Installation checks the format and key pair. The new status display also reports time validity and startup requirements, but clients must still validate the trust chain, access name, and permitted uses.

If the key does not match, locate the certificate issued for the current CSR. Do not regenerate a private key to clear the error. If the result is unconfirmed, refresh and check what was saved before deciding whether to retry.

5.5 Install the client CA chain and test

1. Select Install CA, paste one or more PEM CA certificates used to trust your clients, and select Install.
2. Check the status. A stopped service will attempt startup when credentials and time are ready. If a running service reports changed credentials, restart as instructed to apply them.

3. Access the appropriate test endpoints using a trusted client certificate with the correct purpose and role.
4. Repeat with an untrusted certificate or no certificate, and confirm rejection.

Check the result: HTTPS is running and uses the intended certificate. If Active certificate SHA-256 is displayed, compare its fingerprint. Trusted clients should access only the endpoints their roles permit; untrusted clients should not connect. Verify these outcomes on the actual device.

5.6 Renew certificates or delete all credentials

Certificate expiry: reuse an uncompromised key to request a new certificate, install it, follow the status instructions to apply it, and test again. Config Packs are tied to the recipient certificate fingerprint. Even with the same key, an old package may be rejected after reinitialization or restart because the certificate has changed. Arrange replacement packages beforehand.

Private-key replacement: the old CSR and certificate no longer match the new key. This does not revoke the old certificate at the CA. Handle an exposed key with the CA administrator separately. Packages that depend on a lost key may be unrecoverable.

Delete all credentials: Delete Credentials removes the device key, device certificate, and client CA chain together. Check that HTTP management access works and arrange replacement packages first. A public-certificate backup cannot restore a private key.

After deletion, check for No device certificate and missing credentials. A running HTTPS service may still hold the previous credentials; deleting stored data is not immediate revocation. Restart as instructed and confirm that the old credentials are no longer used. Restore the service with a new key, issued device certificate, client CA chain, and connection tests.

6. Understand Config Pack limitations

A Config Pack is an encrypted, signed `.tscfg` package. Packages can currently be created and inspected, but general configuration application is unfinished. Do not rely on it for production fleet configuration, disaster recovery, or acceptance checks that settings have changed.

6.1 What the controls do

Action	Current result
Export Device Cert	Provides the public certificate so a sender can create a package for this device; does not export its private key
Verify Only	Checks structure and the ciphertext signature against the included certificate; does not establish signer trust or recipient identity
Import after selecting or pasting a package	Frontend and backend parameters still do not match; this flow cannot complete
Import from the package list	Validates an existing device file without copying, decrypting, or applying it
Apply	Decrypts and lists module names without writing their settings; may still report success
Export Config Pack on a Developer device	Creates a downloadable package and attempts to save it to the SD card

6.2 Check the source and recipient

Verification currently uses the signer certificate included in the package without establishing its certificate-chain trust. The signature covers ciphertext; do not assume every displayed field is authenticated. An Official label is not proof of a trusted source.

Use an asset system or an independent trusted channel to confirm the signer fingerprint, target-device certificate, and package purpose. The preview's target name does not replace a certificate fingerprint check. Receiving a certificate and fingerprint in the same message is not an independent check.

6.3 Share the device certificate and inspect a package

To provide this device's certificate: select Export Device Cert and copy the complete PEM and displayed fingerprint. Send the public certificate to the sender and confirm its fingerprint through another trusted channel.

To inspect a received package: open Import Config Pack, select or paste the `.tscfg` file, then select Verify Only. Review signer details and confirm the source. Verification neither applies settings nor proves that this device is the recipient. Stop if the source, target, or purpose is unclear.

Even after verification passes, the current general Import and Apply controls cannot be relied on to configure the device. Use supported controls on the relevant feature pages and check the resulting settings.

6.4 Export from a Developer device

1. Prepare valid JSON configuration files on the SD card and obtain a verified target certificate.
2. Select Export Config Pack, choose files, enter a name and description, and paste the recipient-device certificate.
3. Generate the package, select Download, and check that the browser saved the `.tscfg` file.
4. Check the download and the file under `/sdcard/output_config/` separately. The package may remain available for download even if the SD write fails.

Export does not change source settings. Regenerate a package made for the wrong recipient or a replaced recipient certificate. Successful export does not establish that general application on the receiving device is working.

7. Troubleshooting and incident response

7.1 Common problems

Symptom	What to do
Account Security is missing	It is shown only to root
A key ID is taken or too long	Choose a short, unused ID; see Section 3.1
Key generation is unconfirmed	Wait and inspect the record; do not resubmit the same ID
Deployment completes, but a record is missing or Test fails	Check remote authorization, the local record, and sign-in separately; see Section 3.3
A fingerprint confirmation or change appears	Verify through a trusted channel before deciding to trust it; see Section 4.3
A local record remains after revocation	Check the remote result, then handle local removal failure and service references
Access still works after removing a host	Remove affects only the local record; revoke the remote public key separately
A certificate is saved, but HTTPS is stopped	Check device time, then the displayed credential or startup issue
The running service still uses the old certificate	Restart as instructed, then check the active certificate
A client rejects the certificate	Check client trust, access name, permitted uses, and validity
Apply succeeds, but settings do not change	General application does not write module settings yet; configure them through their feature pages

7.2 Suspected key or password exposure

1. Restrict access to the device and affected material; keep the records needed for investigation.
2. For an exposed SSH private key, revoke its public key on every affected server through trusted connections. Check backups and confirm that the old key no longer works.
3. Create and deploy a new RSA key under a new ID. Verify it, then remove the old key and exported copies.
4. For an exposed SSH password, change it through a trusted management connection and review sign-in records.
5. For an exposed HTTPS key, replace credentials as described in Section 5.6 and work with the CA administrator on revocation and old packages.

The local host list may not cover every server that granted access; also check server and asset records. Before sharing logs, review them for passwords, keys, or other sensitive content entered by users.

7.3 Current operating limits

Account for HTTP management, incomplete centralized authorization, automatic trust on initial deployment, and Config Pack limitations. Hidden is not an access-control mechanism.

The reviewed build configuration does not enable NVS Encryption, Flash Encryption, or Secure Boot. Do not assume these protect stored keys or startup integrity. The flashed firmware configuration and hardware security settings require separate checks. Ask the security owner to arrange isolation or a fix if the intended environment cannot tolerate these limits.

8. Version notes and glossary

8.1 Scope of this edition

This guide is based on the TianShanOS 0.6.1 code and Chinese and English interfaces, reviewed on October 9, 2026. Unchanged features may still be used as described in later versions. If controls, steps, or messages differ, check the release notes for your installed version before proceeding.

The review covered source code and a local simulated interface. Simulation was not treated as acceptance testing on hardware. Check SSH access, TLS handshakes, restarts, and remote authorization in your own environment as described here.

8.2 Terms used in this guide

- **Public key / private key:** share the public key with the administrator who grants access; keep the private key secret. Authentication uses the matching pair.
- **Fingerprint:** a digest used to compare server or certificate identities. Convert differing display formats before comparing.

- **CSR / CA:** a certificate signing request, and a certificate authority or its certificate.
- **CN / O / OU:** common name, organization, and organizational unit in a certificate subject. Department in the form corresponds to OU.
- **SAN / EKU:** the access names or IP addresses a certificate covers, and its permitted authentication purposes.
- **PEM:** a text format with BEGIN/END markers for certificates, CSRs, and keys.
- **mTLS / PKI:** mutual certificate authentication, and the certificate and trust-management system.
- **NVS:** a Flash storage area for device settings and keys; its name does not imply encryption.